

LEVEL - 1

Welcome to Volume 1, Chapter 1 of your Operator Tradecraft manual. To become an elite cybersecurity professional, you must first build the intellectual foundation. Tools change every month, but the way attackers think has remained fundamentally the same for decades.

This module breaks down the philosophy, terminology, and operational rules that separate professional operators from amateurs.

Part 1: The Threat Environment

Before you can defend a network or launch an authorized assessment, you must understand the current state of the digital battlefield and the adversaries who inhabit it.

1. Threat Landscape

The **Threat Landscape** is the collective sum of all potential risks and vulnerabilities present in the digital world at any given moment. It is highly dynamic. When a new technology emerges (like AI or IoT devices), the landscape expands.

- **Zero-Days:** Vulnerabilities that are completely unknown to the software vendor (meaning they have had "zero days" to fix them). These are the most prized weapons on the landscape.
- **Attack Vectors:** The paths attackers take to breach a system, such as phishing emails, unpatched servers, or compromised supply chains.

Operator Insight: The threat landscape always favors the attacker. A defender must plug every single hole; an attacker only needs to find one.

2. Threat Actors

Threat actors are the individuals or groups conducting cyber operations. We classify them not by their skills, but by their *motivations* and *resources*.

- **Script Kiddies:** Novices using pre-written tools. Their motivation is usually notoriety or thrill-seeking.
- **Hacktivists:** Groups (like Anonymous) motivated by ideology. They frequently use DDoS (Distributed Denial of Service) attacks or website defacements to send a political message.
- **Cybercriminals:** Financially motivated actors. They run the massive ransomware operations and underground data-selling markets on the dark web.
- **Nation-State Actors (APTs):** Advanced Persistent Threats. These are government-backed hackers (military or intelligence agencies) focused on espionage, intellectual property theft, or sabotage. They are highly funded and incredibly stealthy.
- **Insider Threats:** Employees or contractors who intentionally or accidentally compromise their own company's security.

Part 2: The Anatomy of an Attack

How exactly does a hack happen? It is rarely a single, magical command. It is a systematic process. Professional operators use standardized models to map out this process.

3. The Cyber Kill Chain

Developed by Lockheed Martin, the Cyber Kill Chain breaks an attack down into a strict, linear sequence. To successfully breach a network and steal data, an attacker must progress through these stages:

1. **Reconnaissance:** Gathering intel on the target (e.g., harvesting email addresses).
2. **Weaponization:** Coupling an exploit with a malicious payload (e.g., a macro inside a PDF).
3. **Delivery:** Sending the weapon to the target (e.g., via a phishing email).
4. **Exploitation:** The weapon triggers the vulnerability on the target's system.
5. **Installation:** The malware installs itself, ensuring the attacker maintains a persistent backdoor.
6. **Command & Control (C2):** The compromised system calls home to the attacker's server, awaiting instructions.
7. **Actions on Objectives:** The final goal (stealing data, encrypting files, or destroying systems).

[Link to an AI video](#)

Operator Insight: As a defender, your goal is to "break the chain" as early as possible. Stopping an attack at the Delivery phase is exponentially cheaper and safer than trying to stop it at the Actions on Objectives phase.

4. MITRE ATT&CK

While the Kill Chain is a high-level strategy, the **MITRE ATT&CK** (Adversarial Tactics, Techniques, and Common Knowledge) framework is the tactical encyclopedia. It moves away from a linear model and instead provides a massive, interactive matrix of exactly *how* hackers achieve their goals.

- **Tactics:** The "Why" (e.g., the attacker wants to gain *Initial Access*).
- **Techniques:** The "How" (e.g., they achieve access via *Spearphishing*).
- **Procedures:** The exact, step-by-step technical implementation.

Software Execution x								
selection controls layer controls technique controls								
Initial Access 9 techniques	Execution 10 techniques	Persistence 18 techniques	Privilege Escalation 12 techniques	Defense Evasion 37 techniques	Credential Access 14 techniques	Discovery 25 techniques	Lateral Movement 9 techniques	Collection 17 techniques
Replication Through Removable Media	Native API	BITS Jobs	Process Injection (8/11)	Obfuscated Files or Information (5/5)	Credentials from Password Stores (3/3)	System Information Discovery	Replication Through Removable Media	Screen Capture
Drive-by Compromise	Windows Management Instrumentation	Hijack Execution Flow (7/11)	Access Token Manipulation (5/5)	Deobfuscate/Decode Files or Information	Network Sniffing	File and Directory Discovery	Lateral Tool Transfer	Data from Local System
Valid Accounts (2/4)	Command and Scripting Interpreter (7/8)	Traffic Signaling (0/1)	Exploitation for Privilege Escalation	Modify Registry	OS Credential Dumping (8/8)	Process Discovery	Exploitation of Remote Services	Audio Capture
Exploit Public-Facing Application	Shared Modules	Valid Accounts (2/4)	Hijack Execution Flow (7/11)	Process Injection (8/11)	Brute Force (3/4)	System Network Configuration Discovery	Taint Shared Content	Archive Collected Data (3/3)
External Remote Services	Scheduled Task/Job (3/6)	Account Manipulation (1/4)	Valid Accounts (2/4)	Indicator Removal on Host (5/6)	Steal Web Session Cookie	System Owner/User Discovery	Remote Services (6/6)	Clipboard Data
Hardware Additions	Software Deployment Tools	Browser Extensions	Boot or Logon Autostart Execution (8/12)	Access Token Manipulation (5/5)	Two-Factor Authentication Interception	Query Registry	Software Deployment Tools	Video Capture
Phishing (2/3)	Inter-Process Communication (2/2)	Boot or Logon Autostart Execution (8/12)	Group Policy Modification	Virtualization/Sandbox Evasion (3/3)	Unsecured Credentials (4/6)	System Network Connections Discovery	Internal Spearphishing	Automated Collection
Supply Chain Compromise (1/3)	System Services (2/2)	Compromise Client Software Binary	Scheduled Task/Job (3/6)	BITS Jobs	Exploitation for Credential Access	System Time Discovery	Remote Service Session Hijacking (1/2)	Data from Removable Media
Trusted Relationship	User Execution (2/2)	External Remote Services	Abuse Elevation Control Mechanism (4/4)	Hijack Execution Flow (7/11)	Forced Authentication	System Service Discovery	Use Alternate Authentication Material (2/4)	Man in the Browser
		Scheduled Task/Job (3/6)	Boot or Logon Initialization Scripts (3/5)	Masquerading (5/6)	Input Capture (3/4)	Peripheral Device Discovery		Data from Network Shared Drive
		Boot or Logon Initialization Scripts (3/5)	Create or Modify System Process (4/4)	Traffic Signaling (0/1)	Man-in-the-Middle (1/2)	Remote System Discovery		Data from Cloud Storage Object
		Create Account (2/3)	Event Triggered Execution (10/15)	Valid Accounts (2/4)	Modify Authentication Process (3/4)	Application Window Discovery		Data from Configuration Repository (0/2)
		Create or Modify System Process (4/4)		Indirect Command Execution	Steal Application Access Token	Network Service Scanning		Data from Information Repositories (1/2)
		Event Triggered Execution (10/15)		Group Policy Modification	Steal or Forge Kerberos Tickets (3/4)	Network Share Discovery		Data Staged (1/2)
		Implant Container Image		Rogue Domain Controller		Software Discovery (1/1)		Email Collection (2/3)
				XSL Script Processing		Network Sniffing		Input Capture (3/4)
				Abuse Elevation Control Mechanism (4/4)				
				Direct Volume Access				

The MITRE ATT&CK Matrix. Source: MITRE ATT&CK®

Part 3: Intelligence & Risk Management

Elite operators do not guess; they make data-driven decisions.

5. Intelligence Lifecycle

Cyber Threat Intelligence (CTI) is information that has been collected, analyzed, and contextualized. Generating CTI follows a strict loop:

1. **Direction:** Defining what information the security team actually needs.
2. **Collection:** Gathering raw data (logs, dark web chatter, malware samples).
3. **Processing:** Formatting the data (decrypting files, translating foreign languages).
4. **Analysis:** Connecting the dots to find meaning. (e.g., "These logs show the same malware signature used by a known Russian APT.")
5. **Dissemination:** Delivering the finished intelligence to decision-makers.
6. **Feedback:** Asking if the intelligence was actually useful, which starts the loop over.

6. Risk Thinking

In business, you cannot secure everything 100%. Cybersecurity is ultimately an exercise in risk management. The fundamental equation is: **Risk = Likelihood (Threat × Vulnerability) × Impact**

- **Threat:** Who is attacking?
- **Vulnerability:** Where are the weak spots?
- **Impact:** If they succeed, how much money/reputation do we lose?

Use this interactive matrix to see how changing the variables alters the severity of the risk:

Operator Insight: Sometimes the correct decision is to simply *accept* the risk. If a system costs ₹50,000 to secure, but the data on it is only worth ₹5,000, accepting the risk is the mathematically correct business choice.

Part 4: The Operator's Code

To hack legally, you must understand the rules of the game.

7. Security Methodologies

When testing a network, operators use different visibility levels:

- **Black Box:** You act as a true external attacker. The client gives you nothing but a company name. You must discover the assets, map the network, and find vulnerabilities entirely on your own.
- **White Box:** The client gives you full access—source code, network diagrams, and admin accounts. This is faster and more comprehensive, but less realistic.
- **Gray Box:** A hybrid approach. You might be given a standard user account to see what an insider threat could accomplish.

8. Ethics

Cybersecurity relies on trust. We categorize operators by their ethics:

- **White Hats:** Ethical hackers who test systems with permission to fix flaws.

- **Black Hats:** Malicious hackers who break in for personal gain or destruction.
- **Gray Hats:** Hackers who break into systems without permission, but instead of stealing data, they report the flaw to the owner (sometimes asking for a bounty). This is legally murky and generally advised against.

9. Rules of Engagement (RoE)

The RoE is your holy grail during an operation. It is a legally binding document that specifies exactly:

- **Scope:** Which IPs, domains, and applications are you allowed to attack?
- **Exclusions:** What is strictly off-limits? (e.g., "Do not test the main payroll server.")
- **Timing:** When can you attack? (e.g., "Only between 1:00 AM and 4:00 AM.")
- **Methods:** Are you allowed to use social engineering? Can you run Denial of Service attacks?

10. Legal Foundations

Cyber laws vary wildly across the globe.

- In India, the **Information Technology (IT) Act, 2000** governs cybercrime. Unauthorized access to computer systems (Section 43/66) carries severe penalties.
- In the US, the primary law is the **Computer Fraud and Abuse Act (CFAA)**.
- In Europe, **GDPR** mandates strict data privacy, heavily impacting how companies report breaches.

Operator Insight: The absolute golden rule of professional offensive security: **Never touch a system without explicit, written authorization.** Verbal permission is not enough. Without a signed RoE, a penetration test is just a felony.

LEVEL - 2

Welcome to Volume 1, Chapter 2 of your Operator Tradecraft manual. If Module 1 was about understanding the game, Module 2 is about studying your opponent before you make a move.

In offensive security, a common saying is: *"Give me six hours to hack a network, and I will spend the first four gathering reconnaissance."* You cannot attack what you cannot see. This phase is all about legally and stealthily gathering data to build a complete picture of your target.

Part 1: The Art of Collection

To hack a target, you first need data. But how you collect that data matters just as much as what you find.

1. OSINT (Open-Source Intelligence)

OSINT is the foundation of modern reconnaissance. It is the systematic collection and analysis of publicly available information. It is not "hacking"—it is advanced digital sleuthing.

- **Technical OSINT:** Searching public databases for DNS records, registered domains, or IP addresses. Tools like *Shodan* (a search engine for internet-connected devices) allow operators to find exposed servers without ever touching them directly.
- **Human OSINT (SOCMINT):** Social Media Intelligence. Analyzing LinkedIn to find the names of system administrators, or searching GitHub to see if an employee accidentally uploaded a company password in their code.

Operator Insight: People are often the weakest link in security. A company might have a million-dollar firewall, but if an employee posts a selfie with their password on a sticky note in the background, the firewall is useless.

2. Collection Methodologies

When gathering intel, operators must choose their approach carefully based on the Rules of Engagement (RoE) and their desired level of stealth.

- **Passive Reconnaissance:** You never directly interact with the target's servers. You only look at third-party sources (like Google, public records, or the Internet Archive). The target has no idea you are looking at them.
- **Active Reconnaissance:** You interact directly with the target. This includes pinging their servers, browsing their website, or running port scans (like using the tool *Nmap*). Active recon yields better data but leaves your IP address in the target's logs, risking detection.

Part 2: Mapping the Target

Once you are collecting data, you need to structure it. You are trying to build a blueprint of the target's digital footprint.

3. Target Profiling

Before looking at computers, you look at the organization. Target profiling is building a dossier on the company's structure and behavior.

- What is their core business? (A bank has different security than a hospital).
- Who are their vendors and partners? (Sometimes it's easier to hack a small third-party vendor to gain access to the main target).
- What is their technology stack? (Do they use Microsoft Windows or Linux? AWS or Google Cloud?)

4. Asset Discovery

An "asset" is any digital property owned by the target. Large corporations often have thousands of assets, many of which they have forgotten about.

- **Subdomain Enumeration:** Finding hidden parts of a website (e.g., finding `dev.target.com` or `vpn.target.com` instead of just `www.target.com`).
- **Acquisition Mapping:** If Company A buys Company B, Company B's old, insecure servers are now Company A's problem. Operators actively look for these forgotten acquisitions.

5. Attack Surface Mapping

If Asset Discovery is finding all the buildings a company owns, **Attack Surface Mapping** is finding all the doors and windows on those buildings.

- You look for open ports (like SSH or RDP) that allow remote access.
- You map out login portals, API endpoints, and upload forms.
- The goal is to identify the "path of least resistance" into the network.

Part 3: Understanding the Adversary

Defenders use reconnaissance too. When a hack occurs, analysts must figure out what happened and who did it.

6. Threat Intelligence

As mentioned in Module 1, Threat Intelligence is contextualized data. We break it down into three levels:

- **Tactical Intel:** The highly technical details. Indicators of Compromise (IoCs) like specific malicious IP addresses, file hashes, or domain names used by malware.
- **Operational Intel:** Understanding an attacker's behavior. The Tools, Techniques, and Procedures (TTPs) they use. For example, knowing a specific hacker group always uses phishing emails containing Excel macros.
- **Strategic Intel:** High-level trends for executives. (e.g., "Ransomware attacks on Indian healthcare providers have increased by 40% this quarter.")

7. Attribution Concepts

Attribution is the process of identifying *who* is behind an attack. It is notoriously difficult.

- **False Flags:** Hackers lie. A Chinese hacker group might write their malware code with Russian comments inside it, or route their attacks through servers in Brazil, to throw analysts off their trail.

- **Diamond Model:** Analysts use frameworks like the Diamond Model of Intrusion Analysis to connect the **Adversary**, the **Infrastructure** they used, the **Capability** (malware), and the **Victim** to make educated guesses about attribution.

Part 4: Tradecraft & Administration

Professionalism is what separates operators from amateurs. How you handle your research matters.

8. Research Tradecraft

When conducting OSINT or Active Reconnaissance, you must protect your own identity.

- **Sock Puppets:** Fake online personas with fully developed backstories, used to infiltrate hacker forums or view social media without using your real, personal accounts.
- **Clean Environments:** Never do research on your personal laptop. Operators use disposable Virtual Machines (VMs) routed through VPNs or the Tor network to ensure malware or tracking scripts don't infect their actual computers.

9. Intelligence Validation

Data is useless if it is inaccurate. The internet is filled with honeypots (fake systems designed to trap hackers) and outdated information.

- Operators must cross-reference data. If a leaked database from 2024 shows an employee's password, you must validate if that employee still works there in 2026 and if the password format matches current company policies.

10. Reporting Notes

The most boring but most critical part of the job.

- **If it isn't documented, it didn't happen.** When you find a vulnerability, you must log the exact time, the exact IP address, the exact command you ran, and a screenshot of the result.
- Without pristine notes, you cannot write the final report for the client, and you cannot prove that *you* didn't accidentally break their server during the test.

Module 2 has given you the blueprint of the target. You've gathered the intel, mapped the attack surface, and safely documented your findings.

Are you ready to move on to Module 3 (Operational Tradecraft), where we finally learn how to weaponize this data, set up attack infrastructure, and execute the campaign?

LEVEL - 3

Welcome to Volume 1, Chapter 3 of your Operator Tradecraft manual. You have the mindset (Module 1), and you have the intelligence (Module 2). Now, we step into the most technical and high-stakes phase: **Operational Tradecraft**.

This is where the actual "hacking" happens. But professional operators don't just throw exploits at a wall to see what sticks. They build secure infrastructure, work as a highly coordinated team, and execute their plans with military precision.

Let's break down Level 3.

Part 1: The Shadows (Stealth & Setup)

Before you launch an attack, you must ensure you cannot be easily traced or blocked. If the defenders (the Blue Team) catch you on day one, the operation is a failure.

1. OPSEC Fundamentals (Operations Security)

OPSEC is the practice of protecting your own operational details from the adversary. For a hacker, bad OPSEC leads to jail; for a Red Teamer, bad OPSEC ruins the assessment.

- **Isolation:** Never mix personal and operational identities. If you log into your personal Spotify or Gmail account on the same virtual machine you use to hack, you have blown your OPSEC.
- **Pattern Avoidance:** Defenders look for anomalies. If you always launch attacks at 2:00 AM IST, defenders will write a rule to block suspicious traffic at that time. Operators must randomize their behaviors.

2. Infrastructure Concepts

You do not hack from your college dorm Wi-Fi. Operators build disposable, layered networks called **Attack Infrastructure**.

- **Command and Control (C2):** Once a payload executes on a target's machine, it needs to "call home" for instructions. The C2 server is the brain of your operation.
- **Redirectors:** If a defender spots your C2 server and blocks its IP, you lose your access. To prevent this, operators place "redirectors" (cheap, disposable cloud servers) in front of the C2. The target talks to the redirector, and the redirector forwards it to the C2. If the redirector gets blocked, you just spin up a new one.

3. Evasion Concepts

Defenders have powerful tools like Antivirus (AV) and Endpoint Detection and Response (EDR) software.

- **Obfuscation:** Scrambling your malicious code so that the AV scanners don't recognize its "signature."
- **Living off the Land (LotL):** Instead of bringing custom malware onto the target system, you use the system's own built-in tools (like PowerShell in Windows or Bash in Linux) to conduct your attack. EDRs struggle to block LotL attacks because they look like normal administrative tasks.

Operator Insight: The best hackers don't write complex, invisible malware. They steal an administrator's credentials and simply log in through the front door. It is the ultimate evasion technique.

Part 2: The Strike (Execution & Access)

With infrastructure in place, it is time to execute the mission. This requires strict coordination.

4. Campaign Planning

A Red Team engagement is a campaign. It requires a master document detailing:

- **Objectives:** What are we trying to achieve? (e.g., "Gain access to the SWIFT banking terminal.")
- **Timelines:** When does the phishing campaign start? When do we attempt internal lateral movement?
- **Deconfliction:** A process to verify if a detected attack is the Red Team, or if a *real* cybercriminal happens to be attacking the client at the same time.

5. Team Operations

Advanced hacking is not a solo endeavor. A Red Team is divided into specialized roles:

- **Team Lead:** Manages the client, oversees the campaign, and handles deconfliction.
- **Operators:** The keyboard warriors executing the exploits and moving through the network.
- **Exploit Developers / Malware Authors:** The programmers who write custom tools and payloads to bypass specific defenses.
- **Infrastructure Admins:** The engineers keeping the C2 servers and redirectors online.

6. Access Management

Getting a "shell" (command-line access to a compromised machine) is hard. Losing it is easy.

- **Persistence:** As soon as you gain access, your first priority is installing a backdoor so that if the user reboots their computer, you don't lose your connection.
- **Credential Handling:** When you steal a list of passwords, they must be stored in a centralized, encrypted database for your team. If you leave stolen passwords in plain text on a compromised server, a rival hacker group might find them and steal your hard work.

Part 3: The Mindset (Decisions & Professionalism)

The difference between a skilled amateur and a professional operator lies entirely in how they behave during and after the operation.

7. Decision Frameworks

Operations are chaotic. Servers crash, payloads fail, and defenders will eventually spot you. Operators use mental models to survive the chaos.

- **The OODA Loop:** Invented by military fighter pilots, it stands for **Observe, Orient, Decide, Act**.
 - *Observe:* The defender just closed the port I was using.
 - *Orient:* I still have a secondary backdoor on another server.
 - *Decide:* I will activate the secondary backdoor and slow down my traffic.
 - *Act:* Execute the command.
 - The operator who cycles through the OODA loop faster wins the engagement.

8. Evidence Handling

When you breach a critical database, you must prove you were there *without* actually stealing the client's sensitive data.

- You take screenshots of directory listings, read benign files (like the `hostname` or `whoami` commands), and cryptographically hash the evidence.
- **Rule of thumb:** Do no harm. Never modify, delete, or expose client data.

9. Documentation

This is the ultimate product of your work. The client is paying you to show them how to fix their network.

- An operator must write detailed "Attack Narratives"—a step-by-step story of exactly how they bypassed the defenses, what vulnerabilities they chained together, and precisely how the Blue Team can patch them.

10. Simulation Planning (Adversary Emulation)

Sometimes, clients don't want you to just "hack" them; they want you to pretend to be a specific threat actor.

- If a bank wants to know if they can survive an attack by *Lazarus Group* (a notorious North Korean APT), the Red Team will study Lazarus Group's threat intelligence (from Module 2) and configure their infrastructure and malware to exactly mimic Lazarus Group's behavior. This is called Adversary Emulation.

That concludes the deep dive into Level 3! You now have a complete theoretical overview of the Operator Tradecraft journey—from the initial security mindset, through the meticulous reconnaissance phase, all the way to executing and documenting a coordinated strike.